CRISC Hard Practice Exam – 100 Real-Life Questions

Harder Scenarios, Calculations and Judgment Calls

CRISC Mastery Series

October 25, 2026

Instructions

How to Use This Deck

Think like a risk practitioner in a real organization.
Focus on business context, ownership, and practical decision-making.
The answer and a key takeaway are on the slide following each question.

Outline

1. Governance (26 percent of the exam) – Hard
2. Risk Assessment (20 percent of the exam) – Hard
3. Risk Response and Reporting (32 percent of the exam) – Hard
4. Information Technology and Security (22 percent of the exam) – Hard
5. Conclusion

Q1: Cumulative Acceptance

Question

Three department heads each accepted a medium risk within their own authority limits. All three risks depend on the same unpatched platform, and together they exceed the enterprise appetite. What is the **BEST** action?

(A) Aggregate the risks and escalate the combined exposure to the authority level that covers it

(B) Keep each acceptance as approved, since every one was within its owner's limit

(C) Reverse all three acceptances and require the platform to be patched at once

(D) Ask each department head to re-rate their risk so the total falls inside appetite

Q1: Explanation

Correct Answer: A

- Authority limits apply to the aggregate exposure, not only to each item.
- A common cause means the risks move together.
- Escalation lets the right level decide whether to respond or accept.

Key Takeaway

Valid one by one can still be unacceptable together.

Q2: Board-Approved Appetite Breach

Question

The board approved a strategic initiative that, by the risk team's assessment, pushes exposure above the stated appetite. What is the risk practitioner's **BEST** action?

(A) Record and report the breach, confirm the board's decision, and monitor

(B) Block the initiative until the exposure is brought back inside the stated appetite

(C) Amend the appetite statement so that the approved initiative no longer breaches it

(D) Take no action, because a board decision settles the matter and needs no record

Q2: Explanation

Correct Answer: A

- The board has authority to exceed appetite knowingly.
- The decision and rationale must be recorded transparently.
- Monitoring and review dates keep the exception visible.

Key Takeaway

The board may exceed appetite, but not invisibly.

Q3: CISO and Business Deadlock

Question

The CISO rates a risk as unacceptable. The business unit head says the system is critical and wants to proceed. Who should **ultimately** decide?

(A) The CISO, because security expertise should prevail over business preference here

(B) The business unit head, because they own the system and bear its operational impact

(C) The risk practitioner, acting as a neutral party between the two disagreeing leaders

(D) The accountable executive or governance body, informed by both views

Q3: Explanation

Correct Answer: D

- Decision rights follow authority limits, not expertise alone.
- Both views inform the choice.
- Practitioners facilitate but do not decide.

Key Takeaway

Expertise advises; authority decides.

Q4: Powerful Executive Exception

Question

A senior executive asks for an exception to a data handling policy that applies to everyone else, citing urgency. What is the **BEST** response?

(A) Process it through the standard exception procedure, with risk assessment, approval, and an expiry date

(B) Grant it right away, because the executive's seniority and urgency justify skipping steps

(C) Refuse it outright, because the policy applies to everyone and allows no exceptions

(D) Grant it informally now and document the exception once the urgent work is finished

Q4: Explanation

Correct Answer: A

- Equal treatment protects the culture.
- The procedure can still be fast.
- Expiry and approval keep accountability.

Key Takeaway

Seniority does not bypass the process.

Q5: Outsourced Risk Function

Question

The risk function is outsourced to the same firm that implements the organization's controls. What is the **PRIMARY** concern?

(A) A conflict of interest that can impair objectivity of risk reporting

(B) Higher hourly rates compared with employing an internal risk team directly

(C) Insufficient technical skill among outsourced staff to understand the controls

(D) Slower communication between the outsourced team and internal management

Q5: Explanation

Correct Answer: A

- The firm would assess its own work.
- Objectivity supports credible reporting.
- Safeguards or separate providers reduce the conflict.

Key Takeaway

Do not let providers grade their own work.

Q6: Overlapping Frameworks

Question

The organization must adopt controls from several frameworks, and they overlap and sometimes conflict. How should the practitioner **FIRST** prioritize?

(A) Start with whichever framework contains the largest number of individual controls

(B) Start with the framework that is most popular among peer organizations in the industry

(C) Start with mandatory legal and regulatory requirements, then map voluntary frameworks to them

(D) Start with the framework the external auditors say they are most familiar with

Q6: Explanation

Correct Answer: C

- Legal obligations are not optional.
- Mapping reduces duplication.
- Voluntary frameworks add value around the mandatory core.

Key Takeaway

Mandatory first, voluntary mapped onto it.

Q7: Survey vs Metrics

Question

A culture survey shows employees in one unit fear reporting mistakes, yet that unit's incident metrics are the best in the company. How should this be interpreted?

(A) The unit is performing best and should be recognized as a model for the company

(B) The survey is unreliable because it contradicts the hard incident metrics

(C) Low reporting may mean underreporting, so investigate before celebrating

(D) Metrics should always outweigh perception surveys when the two disagree

Q7: Explanation

Correct Answer: C

- Fear suppresses reporting.
- Good numbers can mask a poor culture.
- Triangulate with other evidence.

Key Takeaway

Perfect numbers in a fearful unit are suspicious.

Q8: Qualitative Appetite

Question

The appetite statement says low appetite for cyber risk with no measures. What should be done **FIRST** to make it usable?

(A) Invest in additional security tools so the organization can achieve a low appetite

(B) Translate it into measurable tolerances and thresholds approved by management

(C) Ask each team to interpret low appetite in its own way and report back

(D) Withdraw the statement, because qualitative appetite statements are not usable

Q8: Explanation

Correct Answer: B

- Unmeasurable statements cannot guide decisions.
- Tolerances enable indicators.
- Approval ensures authority.

Key Takeaway

Make appetite measurable before using it.

Q9: Subsidiary Acceptance Affecting Group

Question

A subsidiary accepted a risk within its limits, but a compromise there would expose group customer data. What should group governance do?

(A) Respect the subsidiary's local authority because the acceptance followed its own limits

(B) Assess the group-level impact and require escalation to the level that covers group exposure

(C) Prohibit every subsidiary from accepting any risk without group-level review

(D) Take no action unless the subsidiary actually suffers a compromise

Q9: Explanation

Correct Answer: B

- Risk can propagate beyond the entity.
- Authority limits should consider group impact.
- Escalation aligns accountability.

Key Takeaway

Local acceptance should not hide group exposure.

Q10: Departing Risk Owner

Question

A key risk owner is leaving in two weeks. What is the **BEST** action regarding their risks?

(A) Leave the owner field blank until a permanent replacement has been hired

(B) Assign the risks to the risk practitioner so that the register stays complete

(C) Reassign ownership to a successor and hand over status and open actions

(D) Close the risks, since the person who understood them is leaving the company

Q10: Explanation

Correct Answer: C

- Ownerless risks drift.
- Handover preserves context.
- Successors need authority.

Key Takeaway

Reassign risks before the owner leaves.

Q11: Delegation After Reorganization

Question

A reorganization eliminated the role that held acceptance authority for several risks. What should happen?

(A) Assume the authority passed automatically to the manager of the successor team

(B) Leave the existing acceptances in force without any review of their approvers

(C) Re-establish delegated authority for the new structure and re-confirm affected acceptances

(D) Delete the affected acceptances and re-rate each risk as unaccepted

Q11: Explanation

Correct Answer: C

- Authority must be explicit.
- Existing acceptances may lack valid approvers.
- Review restores clarity.

Key Takeaway

Authority does not transfer by assumption.

Q12: Strategy Without Risk Input

Question

A new IT strategy was approved without risk input. What should the practitioner do **FIRST**?

(A) Publicly oppose the strategy until risk has been formally included in planning

(B) Wait until implementation begins, then assess the risks that have appeared

(C) Rewrite the strategy document so that it reflects the risk team's preferences

(D) Assess how the strategy changes the risk profile and present findings to decision makers

Q12: Explanation

Correct Answer: D

- Information, not obstruction, is the role.
- Early input is still valuable.
- Decision makers may adjust.

Key Takeaway

Late input is better than none.

Q13: Reduced Second Line

Question

Management cuts the second-line risk team to save cost and expects first-line self-assessment alone. What is the **PRIMARY** concern?

(A) Lower payroll costs that reduce the budget available to the business units

(B) Fewer scheduled meetings between management and the remaining risk staff

(C) Loss of independent oversight and challenge of the first line

(D) Reduced reporting volume that makes the register harder to maintain

Q13: Explanation

Correct Answer: C

- Self-assessment lacks challenge.
- The second line provides consistency.
- Assurance needs independence.

Key Takeaway

Do not remove the challenge function.

Q14: Audit Consulting Limits

Question

Internal audit is asked to advise on control design for a new system and later audit it. What is the **BEST** safeguard?

(A) Design the controls fully, then audit them to demonstrate their effectiveness

(B) Limit advice to guidance, leave design to management, and disclose the role

(C) Refuse all advice of any kind to stay clear of every possible conflict

(D) Keep the earlier involvement confidential so the audit appears independent

Q14: Explanation

Correct Answer: B

- Consulting is acceptable within limits.
- Management must own decisions.
- Disclosure protects objectivity.

Key Takeaway

Advise, do not design, then audit.

Q15: Compliance vs Risk Culture

Question

Staff treat security as a checklist to pass audits and ignore risks outside the checklist. Which governance change **BEST** addresses this?

(A) Add more items to the checklist so that it covers each additional risk area

(B) Increase the frequency of audits so staff pay closer attention to the checklist

(C) Link controls to objectives and reward people for identifying new risks

(D) Replace the checklist with a single annual statement of compliance

Q15: Explanation

Correct Answer: C

- Checklists miss emerging risk.
- Purpose motivates better behavior.
- Incentives reinforce culture.

Key Takeaway

Teach the why, not just the checklist.

Q16: Are We Secure?

Question

The board asks, are we secure? What is the **BEST** response?

(A) Answer yes, because the controls in place meet every current requirement

(B) Explain the position against appetite, with gaps and trends, not a yes or no

(C) Answer no, because every organization is exposed to some serious level of risk

(D) Decline to answer, because security status cannot be summarized for a board

Q16: Explanation

Correct Answer: B

- Absolute security is unrealistic.
- Risk against appetite is meaningful.
- Gaps and trends support decisions.

Key Takeaway

Answer in risk against appetite, not yes or no.

Q17: Acquirer Appetite Mismatch

Question

A conservative acquirer buys a high-risk-tolerance startup. What is the **BEST** governance approach?

(A) Impose every acquirer policy on day one without assessing the startup first

(B) Leave the two appetites unchanged and let each entity run independently

(C) Adopt the startup's higher tolerance as the appetite for the whole group

(D) Define how appetite applies to the combined entity and plan the transition

Q17: Explanation

Correct Answer: D

- Cultures differ.
- A plan balances risk and integration.
- Clear expectations reduce conflict.

Key Takeaway

Align appetite with a realistic transition.

Q18: In-Flight Regulatory Change

Question

A new regulation affects a project that is already halfway through development. What should the practitioner do?

(A) Ignore the change until the project reaches its planned launch date

(B) Assess impact on requirements and risks, and advise on options and timing

(C) Cancel the project automatically because compliance cannot be retrofitted

(D) Keep the impact quiet so the project team is not discouraged

Q18: Explanation

Correct Answer: B

- Late discovery raises cost.
- Options help decisions.
- Compliance deadlines matter.

Key Takeaway

Assess regulatory impact and give options.

Q19: Shared Service Ownership

Question

An HR system is used by many departments, and each assumes someone else owns its risks. What is the **BEST** fix?

(A) Split ownership evenly so that each using department owns part of the risk

(B) Assign a clear business owner for the shared service with accountability for its risks

(C) Assign the system to the IT department because IT operates the servers

(D) Leave ownership open until a serious incident forces a decision

Q19: Explanation

Correct Answer: B

- Shared use needs single accountability.
- Owners consult users.
- Clear ownership avoids gaps.

Key Takeaway

Shared services still need one owner.

Q20: Unapproved SaaS Purchase

Question

A department bought a SaaS tool with a corporate card, and it already holds customer data. What should be done **FIRST**?

(A) Cancel the corporate card immediately without analyzing what data is involved

(B) Assess the data and vendor controls, then decide with the owner

(C) Take no action, since the tool is already in use and the data is uploaded

(D) Discipline the employee who made the purchase and consider the issue closed

Q20: Explanation

Correct Answer: B

- Understand exposure first.
- Owners decide with facts.
- Process improvement follows.

Key Takeaway

Assess before reacting.

Q21: Retaliation Concern

Question

A practitioner who reported a material risk fears retaliation. Which governance mechanism **BEST** helps?

(A) Remain silent about the concern to avoid any possibility of retaliation

(B) A whistleblower protection policy with an independent reporting channel

(C) Post the concern publicly on an external site to create accountability

(D) Resign immediately so that no retaliation can be directed at the practitioner

Q21: Explanation

Correct Answer: B

- Protection encourages reporting.
- Independent channels reduce conflicts.
- Culture depends on trust.

Key Takeaway

Protect those who raise concerns.

Q22: Unverified Anonymous Tip

Question

An anonymous message alleges serious control override by a manager, with no evidence. What should happen?

(A) Disregard it because an anonymous message has no value without evidence

(B) Confront the manager in person to ask for an explanation of the allegation

(C) Circulate it to the leadership team so everyone is aware of the claim

(D) Send it through the designated channel for fair, confidential investigation

Q22: Explanation

Correct Answer: D

- Allegations deserve review.
- Fairness protects individuals.
- Confidentiality protects the process.

Key Takeaway

Investigate fairly; presume nothing.

Q23: Retention Conflict Authority

Question

Legal wants to keep records for ten years, while the business wants them deleted after two. Who should **ultimately** resolve this?

(A) The IT department, because it stores the data and runs the systems

(B) Whichever department raises its requirement first in the discussion

(C) The storage vendor, whose platform determines what retention is possible

(D) Governance, such as the data governance council, informed by legal obligations

Q23: Explanation

Correct Answer: D

- Legal obligations set minimums.
- Governance balances needs.
- Decisions should be documented.

Key Takeaway

Governance resolves retention conflicts.

Q24: All Risks Rated Medium

Question

A risk register shows nearly every risk rated medium. What does this **MOST** likely indicate?

(A) Evidence that risk management is working very well across the enterprise

(B) Proof that the assessments are accurate and need no further challenge

(C) Weak differentiation in the rating method, reducing its usefulness for prioritization

(D) A sign that no further risk response is needed during the coming year

Q24: Explanation

Correct Answer: C

- Central tendency bias is common.
- Ratings should discriminate.
- Calibration can help.

Key Takeaway

If everything is medium, nothing is prioritized.

Q25: Appetite vs Capacity

Question

Which relationship **BEST** describes appetite and capacity?

(A) Appetite should exceed capacity to allow the organization to pursue growth

(B) Appetite and capacity are always equal in a well-run organization

(C) Appetite should be set below capacity, with tolerances managing movement within appetite

(D) Appetite and capacity are unrelated concepts used in separate processes

Q25: Explanation

Correct Answer: C

- Capacity is the survivable limit.
- Appetite is a choice within it.
- Tolerances operationalize appetite.

Key Takeaway

Appetite sits below capacity.

Q26: Committee Dominated by IT

Question

The risk committee consists only of IT staff, so business risks are underrepresented. What is the **BEST** improvement?

(A) Keep the committee as it is, because IT understands the technology best

(B) Add business, legal, finance, and operational representatives with defined roles

(C) Dissolve the committee and have IT report risks directly to the CEO

(D) Add more IT staff so that technical risks receive deeper analysis

Q26: Explanation

Correct Answer: B

- Risk spans the business.
- Diverse views improve decisions.
- Roles clarify contributions.

Key Takeaway

A risk committee needs the business at the table.

Q27: Control Net Benefit

Question

A control costs 50,000 dollars per year and reduces annualized loss expectancy from 100,000 to 40,000 dollars. What is the net annual benefit?

(A) 60,000 dollars

(B) 40,000 dollars

(C) 50,000 dollars

(D) 10,000 dollars

Q27: Explanation

Correct Answer: D

- Risk reduction is 100,000 minus 40,000, or 60,000.
- Subtract the 50,000 annual cost.
- The net benefit is 10,000, so the control is marginally justified.

Key Takeaway

Net benefit = loss reduction minus control cost.

Q28: Frequency From History

Question

The company had three similar incidents in six years. The single loss expectancy is 300,000 dollars. What is the estimated annualized loss expectancy?

(A) 900,000 dollars

(B) 300,000 dollars

(C) 50,000 dollars

(D) 150,000 dollars

Q28: Explanation

Correct Answer: D

- Three incidents in six years is 0.5 per year.
- ALE equals 300,000 times 0.5.
- Use history carefully; it may not predict the future.

Key Takeaway

ALE = SLE times annual rate.

Q29: Probability of At Least One

Question

Four independent vendors each have a 20 percent chance of a significant outage this year. About what is the probability that at least one has an outage?

(A) About 59 percent

(B) 80 percent

(C) 20 percent

(D) 40 percent

Q29: Explanation

Correct Answer: A

- The chance that none fail is 0.8 to the fourth power, about 0.41.
- So at least one fails with probability of about 0.59.
- Many small independent risks add up quickly.

Key Takeaway

Small independent risks aggregate faster than intuition suggests.

Q30: Control With Lower Frequency

Question

A scenario has a single loss of 500,000 dollars at an annual rate of 0.2. A control costing 60,000 dollars per year lowers the rate to 0.05. What is the net annual benefit?

(A) 75,000 dollars

(B) 60,000 dollars

(C) 100,000 dollars

(D) 15,000 dollars

Q30: Explanation

Correct Answer: D

- Original ALE is 100,000 and new ALE is 25,000.
- Reduction is 75,000.
- Subtract the 60,000 cost to get 15,000.

Key Takeaway

Compare reduction in expected loss with the cost.

Q31: Worst-Case Data Loss

Question

Backups run nightly at 2:00 AM. A failure occurs at 1:00 PM the same day. What is the data loss, and how does it compare with a 4-hour RPO?

(A) Up to 4 hours of data is lost, which meets the RPO

(B) Up to 11 hours of data is lost, which exceeds the 4-hour RPO

(C) No data is lost, because the backup completed successfully overnight

(D) Up to 24 hours is lost, so the backup fails every RPO

Q31: Explanation

Correct Answer: B

- Data since the last backup is lost.
- The gap from 2:00 AM to 1:00 PM is 11 hours.
- The backup design does not meet the RPO.

Key Takeaway

RPO must be at least as frequent as the backup interval.

Q32: Dependency Chain Recovery

Question

Process A has an RTO of 4 hours. It depends on system B, which needs 8 hours to recover. What should the assessment conclude?

(A) The 4-hour RTO is met, because process A itself recovers quickly

(B) System B is irrelevant to process A, so only A's own plan matters

(C) Process A's RTO cannot be met unless B's recovery time improves or the RTO is revisited

(D) Both are acceptable, since the longer figure applies only to system B

Q32: Explanation

Correct Answer: C

- Dependencies set the real recovery time.
- The chain is only as fast as its slowest link.
- Mismatches need a decision.

Key Takeaway

Recovery time is limited by dependencies.

Q33: Inherent vs Residual Confusion

Question

A manager says the risk is low because a control exists, but the control has never been tested. How should the practitioner treat the rating?

(A) Unverified: residual risk needs tested control effectiveness

(B) As low, since the manager has confirmed that the control exists

(C) As equal to the inherent rating until the control is retired

(D) As removed from the register, because a control has been identified

Q33: Explanation

Correct Answer: A

- Existence is not effectiveness.
- Testing gives evidence.
- Use judgment until tested.

Key Takeaway

Untested controls give unverified residual risk.

Q34: Control That Creates Risk

Question

A control that forces frequent password changes leads users to write passwords down. What does this illustrate?

(A) A control with an adverse side effect, so effectiveness should include behavioral impact

(B) A strong preventive control that has fully achieved its design purpose

(C) A detective control whose results are visible to management

(D) An irrelevant control that should be ignored in the assessment

Q34: Explanation

Correct Answer: A

- Controls change behavior.
- Side effects can increase risk.
- Evaluate controls in practice, not only on paper.

Key Takeaway

Check what the control does to people.

Q35: Internet-Facing vs Internal

Question

Two vulnerabilities exist: a critical one on an isolated internal server and a high one on an internet-facing system with known active exploitation. Which should usually be prioritized?

(A) The isolated critical one, because its severity score is the higher of the two

(B) The internet-facing one, because exposure and active exploitation raise likelihood considerably

(C) Neither, until the next audit confirms which finding is more urgent

(D) Both equally, without further analysis of context or exploitability

Q35: Explanation

Correct Answer: B

- Risk combines severity, exposure, and exploitation.
- Context changes priority.
- Document the reasoning.

Key Takeaway

Prioritize by exposure and exploitation, not score alone.

Q36: Tail Risk

Question

A scenario has very low probability but catastrophic impact beyond risk capacity, so expected loss looks small. How should it be treated?

(A) Ignore it, because the expected loss is small compared with other risks

(B) Reduce the probability estimate to zero because the event is so rare

(C) Accept it without review, since low-probability events cannot be managed

(D) Not by expected value alone; consider capacity and possible responses

Q36: Explanation

Correct Answer: D

- Averages can hide existential risk.
- Capacity matters.
- Governance should decide knowingly.

Key Takeaway

Do not let averages hide survival risks.

Q37: Survivorship Bias

Question

An assessment uses only data from incidents that were detected. What bias may result?

(A) Overestimation of risk because only the most serious incidents are counted

(B) Underestimation of risk because undetected incidents are missing from the data

(C) No bias, because detected incidents represent the full population

(D) Improved accuracy, since the data comes from verified detections

Q37: Explanation

Correct Answer: B

- Detection is incomplete.
- Data reflects what was noticed.
- Adjust estimates with caution.

Key Takeaway

You cannot count what you never saw.

Q38: Cascading Failure

Question

A power failure disables cooling, which shuts down servers, which stops payment processing. Which analysis technique **BEST** reveals such chains?

(A) Dependency mapping with scenario analysis of cascading effects

(B) A password complexity review across all critical applications

(C) A comparison of annual software licensing costs by vendor

(D) A review of the organization's insurance premiums over time

Q38: Explanation

Correct Answer: A

- Chains cross technical and business layers.
- Scenarios simulate propagation.
- Mapping shows single points of failure.

Key Takeaway

Look for cascades, not isolated failures.

Q39: Assessing Own Implementation

Question

A consultant who implemented a firewall is asked to assess its effectiveness. What is the **MAIN** concern?

(A) Self-review threat: objectivity may be impaired

(B) Higher cost, because the consultant charges premium rates for reviews

(C) A scheduling delay, because the consultant is rarely available

(D) A language barrier between the consultant and the staff

Q39: Explanation

Correct Answer: A

- People tend to defend their own work.
- Independent assessors give stronger assurance.
- Safeguards can limit the threat.

Key Takeaway

Do not mark your own homework.

Q40: Generic vs Specific Intelligence

Question

Generic threat reports say ransomware is rising. A sector-specific alert names a technique targeting your industry. How should they inform likelihood?

(A) Ignore both sources, because neither can be verified independently

(B) Use only generic reports, since they are based on more incidents

(C) Use only the sector alert and discard broader industry trends

(D) Favor relevant, specific intelligence; keep trends as context

Q40: Explanation

Correct Answer: D

- Relevance improves accuracy.
- Trends still set context.
- Document assumptions.

Key Takeaway

Specific beats generic, but context still matters.

Q41: Partial Implementation Timing

Question

A control will be fully deployed in nine months. How should residual risk be reported today?

(A) As if the control were already fully deployed across the environment

(B) As zero, because a remediation plan has already been approved

(C) As unknown, until the control has been completely implemented

(D) Based on current control state, with expected improvement shown separately as a target

Q41: Explanation

Correct Answer: D

- Plans are not controls.
- Targets show intent.
- Honest reporting maintains credibility.

Key Takeaway

Report today's risk, show tomorrow's target.

Q42: Incomparable Scales

Question

Two departments rate risk using different scales, and their scores are compared directly. What is the problem?

(A) There is no problem, because both are numeric scores of risk

(B) Not comparable; align scales and criteria before aggregating

(C) The higher score should be used whenever two scores differ

(D) Averaging the two scores gives a fair enterprise figure

Q42: Explanation

Correct Answer: B

- Different scales mean different meanings.
- Mapping or common criteria are needed.
- Aggregation requires consistency.

Key Takeaway

Do not compare scores built on different scales.

Q43: Inconsistent Scenario Assumptions

Question

Two scenarios use contradictory assumptions about the same control's effectiveness. What should the practitioner do?

(A) Reconcile assumptions with evidence and apply them consistently

(B) Leave them inconsistent, as each scenario owner knows best

(C) Adopt the more optimistic assumption to simplify reporting

(D) Delete one scenario so that no contradiction remains visible

Q43: Explanation

Correct Answer: A

- Consistency supports credibility.
- Evidence should drive assumptions.
- Document the reconciliation.

Key Takeaway

Reconcile assumptions before reporting.

Q44: Risk Interdependency Chain

Question

Risk A, if realized, raises the likelihood of risk B. How should this be reflected?

(A) Treat the two risks as independent to keep the assessment simple

(B) Remove risk B because it is already covered by risk A

(C) Ignore the link until an incident shows that it matters

(D) Document the link and assess the combined impact, not each alone

Q44: Explanation

Correct Answer: D

- Dependencies compound effects.
- Combined assessment improves decisions.
- Responses may target the shared cause.

Key Takeaway

Link related risks.

Q45: Expert Overconfidence

Question

Experts give very narrow confidence ranges, yet past estimates were often far off. What should be done?

(A) Calibrate experts with feedback and widen ranges for real uncertainty

(B) Trust the narrow ranges, because the experts are senior and experienced

(C) Replace expert estimates with unstructured guesses from the team

(D) Ignore past estimation errors as they relate to other scenarios

Q45: Explanation

Correct Answer: A

- Overconfidence is common.
- Calibration improves quality.
- Honest ranges support decisions.

Key Takeaway

Calibrate overconfident estimates.

Q46: Detection Gap in Scenario

Question

A scenario assumes an intrusion would be detected within hours, but monitoring covers only business hours. What should the practitioner do?

(A) Adjust assumptions to real detection capability and reassess

(B) Keep the optimistic assumption, since detection will improve over time

(C) Assume detection is instant, because alerts are generated automatically

(D) Remove the scenario because monitoring gaps are outside its scope

Q46: Explanation

Correct Answer: A

- Assumptions must match reality.
- Dwell time affects impact.
- Document the adjustment.

Key Takeaway

Base scenarios on actual detection capability.

Q47: Impact Beyond Capacity

Question

A scenario's potential loss exceeds the organization's risk capacity, and mitigation can only partly reduce likelihood. Which response is **MOST** appropriate?

(A) Accept the risk, because mitigation cannot remove all of the exposure

(B) Combine mitigation with transfer to bring impact within capacity

(C) Mitigate only, and treat any remaining impact as outside the analysis

(D) Avoid all activity of that type permanently, without further analysis

Q47: Explanation

Correct Answer: B

- Capacity is a hard limit.
- A mix of responses can reduce both likelihood and impact.
- Residual exposure must be survivable.

Key Takeaway

If impact exceeds capacity, combine responses.

Q48: Unauditable Giant Provider

Question

A major cloud provider refuses on-site audits. What is the **BEST** way to obtain assurance?

(A) Stop using the provider, because without audit rights no assurance exists

(B) Accept the provider's marketing statements as sufficient evidence of control

(C) Use independent reports, contractual terms, and your own monitoring

(D) Insist on on-site audits regardless of the provider's stated policy

Q48: Explanation

Correct Answer: C

- Independent reports provide evidence.
- Contracts set expectations.
- Customer-side controls remain your duty.

Key Takeaway

Use independent assurance when audits are not possible.

Q49: Retiring a Compensating Control

Question

The planned permanent fix has been deployed. What should happen to the compensating control?

(A) Remove the compensating control immediately, since the fix has been deployed

(B) Keep the compensating control indefinitely, in case the fix ever fails

(C) Verify the fix works, then retire the control through change control

(D) Leave the compensating control unreviewed and track it only at audit

Q49: Explanation

Correct Answer: C

- Verification prevents gaps.
- Unneeded controls add cost and complexity.
- Change control keeps it managed.

Key Takeaway

Verify the fix before removing the safety net.

Q50: Mid-Period Control Failure

Question

A control failed for two months and then was repaired before the period ended. How should this be reflected in the assessment of the period?

(A) A deficiency for the failure window, with impact assessed

(B) As no issue, because the control was repaired before the period ended

(C) As a failure for all periods, because it failed once

(D) As a minor note kept out of the formal assessment

Q50: Explanation

Correct Answer: A

- Effectiveness is judged over the period.
- Impact depends on what occurred during the gap.
- Repair shows responsiveness.

Key Takeaway

A fixed control still failed during the gap.

Q51: False Green KRI

Question

A KRI has been green for a year, but a major incident occurred in the same area. What should the practitioner conclude?

(A) The KRI is working perfectly and the incident was entirely unrelated

(B) The incident is irrelevant to the KRI because it was an isolated event

(C) The KRI may miss the real risk drivers, so review its design

(D) The KRI should stay unchanged to preserve year-over-year comparison

Q51: Explanation

Correct Answer: C

- Indicators can be poorly chosen.
- Incidents are feedback.
- Redesign improves early warning.

Key Takeaway

Use incidents to test your indicators.

Q52: Report Implicating Management

Question

A risk analysis shows that decisions by a senior executive created a significant exposure. How should this be reported?

(A) Soften the wording or omit the cause to protect the executive's position

(B) Factually and objectively through normal channels, escalating if needed

(C) Name the executive in a broad announcement to enforce accountability

(D) Delay the report until the executive has left the organization

Q52: Explanation

Correct Answer: B

- Facts matter, not personalities.
- Independent oversight protects objectivity.
- Accuracy supports governance.

Key Takeaway

Report facts, even uncomfortable ones.

Q53: Owner Lacks Understanding

Question

A risk owner is about to accept a major risk but clearly does not understand its impact. What should the practitioner do?

(A) Let the owner accept the risk, since the decision is theirs to make

(B) Accept the risk on the owner's behalf to speed up the process

(C) Explain impact, options, and consequences in business terms first

(D) Withhold the technical details so that the owner is not overwhelmed

Q53: Explanation

Correct Answer: C

- Decisions must be informed.
- Plain language helps.
- Documented understanding protects both.

Key Takeaway

An uninformed acceptance is not a real decision.

Q54: Diverted Resources

Question

Resources approved for a risk response were reassigned to another project. What should the practitioner do?

(A) Keep the change quiet, since the other project is a higher priority

(B) Assume the response will resume once the other project is finished

(C) Close the response item, since it is no longer being resourced

(D) Report the residual risk effect and ask the owner to decide

Q54: Explanation

Correct Answer: D

- Exposure persists when responses stall.
- Owners decide trade-offs.
- Transparency protects accountability.

Key Takeaway

Resource diversion changes residual risk.

Q55: Regulation Beats Cost-Benefit

Question

A control fails a cost-benefit test but is required by regulation. What should be done?

(A) Skip it, because costs exceed benefits and the decision is a business one

(B) Implement it for compliance, optimizing cost where possible

(C) Discuss informally with the regulator whether enforcement is likely

(D) Defer it indefinitely until a regulator specifically raises it

Q55: Explanation

Correct Answer: B

- Legal obligations are not optional.
- Cost optimization is still valuable.
- Document the rationale.

Key Takeaway

Mandatory means mandatory.

Q56: Exploited Critical Vulnerability Exception

Question

A business unit requests a long exception for a critical vulnerability that is known to be actively exploited. What is the **BEST** approach?

(A) Approve for one year with no extra controls, to avoid business disruption

(B) Deny the request outright with no alternative path offered

(C) Approve verbally and record the decision later when time allows

(D) Require compensating controls, a short expiry, and executive approval

Q56: Explanation

Correct Answer: D

- Active exploitation raises urgency.
- Short expiry forces action.
- Executive approval reflects risk.

Key Takeaway

High exposure demands strong conditions.

Q57: Self-Validated Remediation

Question

The team that fixed a vulnerability also validates the fix and reports closure. What is the weakness?

(A) No weakness exists, because the team knows the system best

(B) Validation happens too quickly after the fix is applied

(C) The closure report is longer than management needs

(D) No independent verification, so closure may be unreliable

Q57: Explanation

Correct Answer: D

- Independence strengthens assurance.
- Rescans or testing provide evidence.
- Risk may remain.

Key Takeaway

Verify independently.

Q58: Green Dashboard, Real Incident

Question

All dashboard indicators were green the week a serious incident occurred. What is the **MOST** valuable follow-up?

(A) Blame the incident response team for failing to use the dashboard

(B) Ignore the dashboard, since it is unrelated to the incident

(C) Check whether indicators measure the right things and adjust them

(D) Remove all indicators because they failed to predict the incident

Q58: Explanation

Correct Answer: C

- Indicators can miss real risks.
- Lessons learned improve monitoring.
- Measurement should evolve.

Key Takeaway

Learn from the miss to improve the measure.

Q59: Liability Cap

Question

A vendor contract caps liability at one month of fees, but a breach could cost far more. What does this imply?

(A) All financial risk has been transferred to the vendor under the contract

(B) No residual risk remains, because the contract covers the breach

(C) Residual financial risk stays with you and may need other responses

(D) The cap raises the vendor's incentive to invest in better security

Q59: Explanation

Correct Answer: C

- Caps limit recovery.
- Insurance or controls may be needed.
- Negotiation may improve terms.

Key Takeaway

Check caps before assuming transfer.

Q60: Insurance Retention

Question

A cyber policy has a large retention before coverage begins. How should this be considered?

(A) Ignore it, since insurance will cover any loss that occurs

(B) Count the retention as retained loss and ensure reserves exist

(C) Assume full coverage from the first dollar of any loss

(D) Cancel the policy, because a retention makes the insurance worthless

Q60: Explanation

Correct Answer: B

- You pay losses up to the retention.
- Coverage conditions affect value.
- Plan for retained risk.

Key Takeaway

Retention is risk you still hold.

Q61: Failover Cost

Question

Active-active failover would meet the RTO but costs far more than the potential loss reduction. What is the **BEST** approach?

(A) Buy the solution regardless, since the RTO is a firm requirement

(B) Ignore the RTO, because cost is the only factor that matters

(C) Keep the cost out of the discussion with the business owner

(D) Review alternative designs or revisit the RTO on cost-benefit

Q61: Explanation

Correct Answer: D

- Objectives should be cost-justified.
- Alternatives may meet needs.
- Business owns the trade-off.

Key Takeaway

RTO and cost must be reconciled.

Q62: Conflicting KRI Thresholds

Question

Two units set different thresholds for the same indicator. What should be done?

(A) Leave the thresholds different, because each unit knows its own risk

(B) Remove the indicator since the units cannot agree on its meaning

(C) Align thresholds to enterprise appetite; allow approved variation

(D) Adopt the lowest threshold in every unit without further analysis

Q62: Explanation

Correct Answer: C

- Consistency supports aggregation.
- Justified variation is acceptable.
- Approval keeps control.

Key Takeaway

Align thresholds to enterprise appetite.

Q63: Ransom Decision Governance

Question

During a ransomware incident, staff debate whether to pay. Who should make the decision?

(A) Senior leadership with legal, risk, and law enforcement guidance

(B) The service desk lead, since they are closest to the affected users

(C) The first responder alone, because they hold the most facts

(D) The vendor of the affected system, because it knows the platform

Q63: Explanation

Correct Answer: A

- The decision has legal and ethical dimensions.
- A pre-agreed framework avoids panic.
- Experts inform leaders.

Key Takeaway

Decide on ransom through governance, not improvisation.

Q64: Notification vs Incomplete Investigation

Question

A regulator's notification deadline is approaching, but the investigation is incomplete. What is the **BEST** approach?

(A) Notify on time with known facts, say it continues, then update

(B) Wait until the investigation is complete so that the report is accurate

(C) Send a reassuring notice that states no data was affected

(D) Skip the notification until the cause is fully confirmed

Q64: Explanation

Correct Answer: A

- Deadlines are legal requirements.
- Partial information is acceptable if honest.
- Updates follow.

Key Takeaway

Meet the deadline with honest partial facts.

Q65: Near-Breach Transparency

Question

A near-breach was caught by luck. Management wants to keep it quiet. What should the practitioner advise?

(A) Keep it internal to the team, since no loss occurred

(B) Exaggerate it to obtain additional budget for security

(C) Ignore it, because near misses are not formal incidents

(D) Report it; it exposes weaknesses leaders must know

Q65: Explanation

Correct Answer: D

- Near misses are warning signs.
- Transparency enables fixes.
- Hiding it prevents learning.

Key Takeaway

Report near misses; they are cheap lessons.

Q66: Denominator Change

Question

The percentage of unpatched systems fell, but only because many systems were removed from the inventory. How should this be reported?

(A) Report only the improved percentage since it reflects the new inventory

(B) Disclose the inventory change; show percentage and absolute numbers

(C) Leave the inventory change out of the report to avoid confusion

(D) Describe the improvement as proof that remediation has succeeded

Q66: Explanation

Correct Answer: B

- Metric changes can mislead.
- Absolute numbers add context.
- Honesty maintains trust.

Key Takeaway

Explain denominator changes.

Q67: Goodhart's Law

Question

Teams focus on hitting one security metric while neglecting related risks. What principle does this illustrate?

(A) Metrics are always accurate when tied to formal targets

(B) Targets improve every related behavior, not only the measured one

(C) Measurement is unnecessary when teams have clear goals

(D) When a measure becomes a target, it can stop being a good measure

Q67: Explanation

Correct Answer: D

- People optimize what is measured.
- Use balanced indicators.
- Review metrics regularly.

Key Takeaway

Targets can distort the very thing they measure.

Q68: Risk-Based Rollback

Question

A change causes unexpected instability in a critical system. Which action is **BEST**?

(A) Roll back or contain according to the change plan, then investigate the cause

(B) Continue the change, because the original approval remains valid

(C) Ignore the instability and wait to see whether it resolves on its own

(D) Hold the tester responsible and proceed with the rollout

Q68: Explanation

Correct Answer: A

- Stability protects the business.
- Rollback plans exist for this.
- Root cause prevents recurrence.

Key Takeaway

Stabilize first, analyze second.

Q69: Patch vs Availability

Question

A critical patch requires downtime on a system that must run continuously. What should the risk practitioner recommend?

(A) Patch immediately regardless of the impact on continuous operations

(B) Weigh exposure against downtime and use staged patching or windows

(C) Never patch systems that must remain running at all times

(D) Ignore the vulnerability until the next scheduled outage

Q69: Explanation

Correct Answer: B

- Both patching and downtime carry risk.
- Staging reduces impact.
- Owners decide trade-offs.

Key Takeaway

Balance exposure against disruption.

Q70: Monitoring Cost-Benefit

Question

Continuous monitoring of a low-risk process costs more than the process's risk exposure. What is the **BEST** decision?

(A) Keep continuous monitoring, since coverage should never be reduced

(B) Stop all oversight, because the process carries little risk

(C) Use a lighter, periodic approach proportionate to the risk

(D) Switch to random, undocumented checks by whoever is available

Q70: Explanation

Correct Answer: C

- Monitoring should be proportionate.
- Periodic review can suffice.
- Reassess if risk changes.

Key Takeaway

Proportionate monitoring beats maximal monitoring.

Q71: Control Overlap Risk

Question

Two controls overlap, and each team assumes the other performs a key check. What is the risk?

(A) Gaps from assumed coverage, where neither actually performs the check

(B) No risk, since two overlapping controls always strengthen coverage

(C) Improved coverage, because each team will perform the check twice

(D) Lower cost, because each team can reduce its own effort

Q71: Explanation

Correct Answer: A

- Assumption causes omission.
- Clear ownership resolves it.
- Test to confirm coverage.

Key Takeaway

Overlap without ownership breeds gaps.

Q72: SOC 1 vs SOC 2

Question

A vendor provides a SOC 1 report, but you need assurance on security and availability of a hosted service. What is the issue?

(A) The reports are identical, so either one provides the needed assurance

(B) SOC 1 covers all security controls of the hosted service

(C) SOC 1 covers financial reporting; SOC 2 covers security

(D) Assurance reports are irrelevant to security decisions

Q72: Explanation

Correct Answer: C

- Report scope matters.
- Match reports to the risk.
- Request the appropriate report.

Key Takeaway

Match the assurance report to the risk.

Q73: Response Slower Than Threat

Question

The planned response will take 12 months, but intelligence suggests an attack is likely within three. What should the practitioner do?

(A) Add interim controls and escalate the timing mismatch

(B) Wait for the 12-month plan, since it was approved by the owner

(C) Disregard the intelligence, because it has not been confirmed

(D) Cancel the plan and start a new one with a shorter horizon

Q73: Explanation

Correct Answer: A

- Timing affects exposure.
- Interim measures reduce risk.
- Owners must know the gap.

Key Takeaway

Add interim controls when the threat is faster than the fix.

Q74: Bypassing the Escalation Chain

Question

A practitioner bypasses the defined escalation chain to report directly to a board member because they dislike a manager. Why is this concerning?

(A) It is the most effective method and should be preferred in every case

(B) It undermines governance; use defined escalation paths

(C) It strengthens the hierarchy by making senior leaders better informed

(D) It has no governance impact since the board member is senior

Q74: Explanation

Correct Answer: B

- Defined paths ensure consistency.
- Exceptions need justification.
- Personal reasons are not valid.

Key Takeaway

Follow the chain unless independence demands otherwise.

Q75: Vendor With Weak Finances

Question

A critical vendor has accepted the transferred risk contractually but may be unable to pay if a loss occurs. What does this mean?

(A) All risk is gone, because the contract assigns it to the vendor

(B) The vendor is guaranteed to pay, because the contract obliges it

(C) The transfer may fail if the vendor cannot pay

(D) No further action is needed once the contract has been signed

Q75: Explanation

Correct Answer: C

- Contracts need counterparty strength.
- Insurance or guarantees may help.
- Assess financial health.

Key Takeaway

A transfer is only as good as the counterparty.

Q76: Replication vs Backup

Question

A team claims data is protected because it is replicated to a second site in real time. Why is this **NOT** a complete answer?

(A) Replication copies corruption and deletion too, so backups are needed

(B) Replication is sufficient, because it keeps a second copy at all times

(C) Replication is slower than backup, so it cannot support recovery

(D) Replication encrypts data in transit and therefore replaces backup

Q76: Explanation

Correct Answer: A

- Bad changes replicate too.
- Backups provide recovery points.
- Both address different risks.

Key Takeaway

Replication protects availability, not history.

Q77: Paper-Pass DR Test

Question

A DR test passed, but later a real failure revealed missing dependencies. What should the practitioner do?

(A) Rely on past tests, since the plan has passed before

(B) Stop testing, because the real failure proved testing is unreliable

(C) Widen test scope to include dependencies and realistic conditions

(D) Treat the real failure as an anomaly unrelated to the plan

Q77: Explanation

Correct Answer: C

- Tests can miss realistic conditions.
- Dependencies often cause failures.
- Update after lessons learned.

Key Takeaway

A passed test is only as good as its scope.

Q78: Disputed Audit Rating

Question

Audit rates an issue as high, but management says medium. Who should resolve a persisting disagreement?

(A) Escalate to the governance body with both views documented

(B) Management decides alone, because it owns the affected process

(C) The auditor decides alone, because audit ratings are independent

(D) Average the two ratings to produce a neutral, final result

Q78: Explanation

Correct Answer: A

- Independence of audit must be respected.
- Management may accept risk knowingly.
- Governance decides transparently.

Key Takeaway

Unresolved rating disputes go to governance.

Q79: TLS Inspection and Privacy

Question

Security wants to decrypt and inspect all employee web traffic, but legal warns about privacy rules. What is the **BEST** approach?

(A) Inspect all traffic silently to maximize threat visibility

(B) Never inspect any traffic, to avoid the privacy question entirely

(C) Inspect with legal review, notice, and sensitive exclusions

(D) Proceed without legal input, because security takes precedence

Q79: Explanation

Correct Answer: C

- Inspection helps detect threats.
- Privacy obligations limit scope.
- Transparency and exclusions balance both.

Key Takeaway

Balance inspection with privacy by design.

Q80: Zero Trust and Legacy Systems

Question

Legacy applications cannot support modern authentication, but the organization is adopting zero trust. What is the **BEST** approach?

(A) Exclude the legacy systems permanently and apply no extra controls

(B) Remove the legacy systems at once, whatever the business impact

(C) Delay zero trust until all legacy systems have been replaced

(D) Put legacy systems behind gateways, segment, and monitor them

Q80: Explanation

Correct Answer: D

- Legacy cannot always be replaced quickly.
- Compensating architecture reduces exposure.
- Plan modernization.

Key Takeaway

Wrap legacy systems until they can be replaced.

Q81: Key Escrow

Question

The organization considers key escrow so that encrypted data can be recovered if staff leave. What is the main risk?

(A) There is no added risk, because escrowed keys are never used

(B) Encryption is automatically weakened once keys are escrowed

(C) The escrow becomes a high-value target needing tight control

(D) The keys become public as soon as they are placed in escrow

Q81: Explanation

Correct Answer: C

- Escrow concentrates keys.
- Dual control and audit reduce risk.
- Recovery needs must be balanced against exposure.

Key Takeaway

Recoverability creates a new asset to protect.

Q82: Password Storage

Question

Which method **BEST** protects stored user passwords?

(A) Store passwords in plain text to simplify recovery for users

(B) Store them using reversible encryption with one shared key

(C) Store salted hashes with a slow password hashing algorithm

(D) Store unsalted fast hashes so that lookups remain efficient

Q82: Explanation

Correct Answer: C

- Salts defeat precomputed attacks.
- Slow hashing resists brute force.
- Plain text exposes everything in a breach.

Key Takeaway

Hash passwords with salt and slow algorithms.

Q83: RAID Is Not Backup

Question

A manager says data is safe because the storage uses RAID. What is the **BEST** response?

(A) RAID is a complete backup, because data is stored on several disks

(B) RAID covers disk failure, not deletion or ransomware

(C) RAID prevents all data loss events, including accidental deletion

(D) RAID replaces disaster recovery, because it duplicates the data

Q83: Explanation

Correct Answer: B

- RAID addresses hardware faults.
- Logical errors affect all copies.
- Backups provide recovery points.

Key Takeaway

RAID is redundancy, not backup.

Q84: Single Sign-On Outage

Question

The SSO provider has an outage, and no one can access critical applications. What does this reveal?

(A) Concentration risk in the identity provider; plan break-glass access

(B) A well-designed service, since a single outage proves central control

(C) No risk, because identity services are managed by a professional provider

(D) Better redundancy, since every application relies on one login

Q84: Explanation

Correct Answer: A

- Central services are single points of failure.
- Break-glass access supports emergencies.
- Resilience of the IdP matters.

Key Takeaway

Centralized identity needs resilience.

Q85: Wildcard Permissions

Question

A cloud role grants all actions on all resources to a service. What is the **BEST** remediation?

(A) Keep wildcard permissions, because they prevent failures from missing access

(B) Add more wildcard permissions so future services need no changes

(C) Share the role with other services to reduce the number of roles

(D) Apply least privilege: limit actions and resources to what is needed

Q85: Explanation

Correct Answer: D

- Broad roles magnify compromise impact.
- Scoped permissions reduce risk.
- Review regularly.

Key Takeaway

Avoid wildcard permissions.

Q86: Secrets in Serverless

Question

A serverless function stores database passwords in environment variables visible to many staff. What is the **BEST** improvement?

(A) Keep the passwords in environment variables, since the function is private

(B) Email the passwords to the developers who maintain the function

(C) Hard-code the passwords into the function so they are always available

(D) Use a managed secrets service with restricted access and rotation

Q86: Explanation

Correct Answer: D

- Secrets need access control.
- Rotation limits exposure.
- Central management improves audit.

Key Takeaway

Manage secrets centrally.

Q87: Re-identification

Question

A dataset with names removed still contains birth date, postal code, and gender. What is the risk?

(A) There is no risk, because names have been removed from the dataset

(B) Individuals may be re-identified by combining attributes

(C) The data is perfectly anonymous, since direct identifiers are gone

(D) Only an encryption risk exists, and encryption would resolve it

Q87: Explanation

Correct Answer: B

- Quasi-identifiers can single people out.
- Generalization or aggregation reduces risk.
- Assess re-identification before release.

Key Takeaway

Removing names is not anonymization.

Q88: Differential vs Incremental Backups

Question

Which statement is correct about restoring from backups?

(A) Incrementals need only the last incremental backup to restore

(B) Differentials need every previous differential to be restored in turn

(C) Both types need only the most recent backup to restore completely

(D) Differential restores need the last full plus the latest differential

Q88: Explanation

Correct Answer: D

- Differentials include changes since the last full.
- Incrementals include changes since the last backup.
- Restore steps affect RTO.

Key Takeaway

Backup type affects restore complexity.

Q89: Backup Frequency and RPO

Question

The business RPO is 1 hour. Which backup design meets it?

(A) Continuous protection or hourly backups with log shipping

(B) Weekly full backups with daily verification and offsite storage

(C) Nightly backups held on a secondary system in another site

(D) Monthly archives stored in a secure vault with restricted access

Q89: Explanation

Correct Answer: A

- Interval must not exceed the RPO.
- Log shipping reduces gaps.
- Test restoration.

Key Takeaway

Backup interval must fit the RPO.

Q90: Warm Site

Question

The RTO is 24 hours and cost is a concern. Which alternate site is often **MOST** appropriate?

(A) A warm site: equipment in place, data restored on activation

(B) A hot site, because it is always the best choice regardless of cost

(C) No alternate site, because 24 hours is long enough to rebuild

(D) A cold site with space and power but no equipment installed

Q90: Explanation

Correct Answer: A

- Warm sites balance cost and speed.
- Hot sites cost more.
- Cold sites may take too long.

Key Takeaway

Match site type to RTO and budget.

Q91: Encrypted Traffic and IDS

Question

Most network traffic is now encrypted, reducing the value of network intrusion detection. What is the **BEST** compensating approach?

(A) Rely on network intrusion detection alone, as it still sees all traffic

(B) Add endpoint and identity detection plus selective decryption

(C) Disable network detection, since encryption makes it unusable

(D) Block all encrypted traffic so that inspection becomes possible

Q91: Explanation

Correct Answer: B

- Visibility needs to move.
- Metadata still reveals patterns.
- Endpoint tools see decrypted activity.

Key Takeaway

When traffic is encrypted, move detection to the endpoints.

Q92: Unknown Component Exposure

Question

A critical vulnerability is announced in a widely used library, and the organization does not know where it is used. What is the **BEST** long-term fix?

(A) Assume the library is not used, since no team has reported it

(B) Ask each developer to recall from memory where it might be used

(C) Keep software inventories and SBOMs, and enable component search

(D) Wait for the vendor to publish a list of affected customers

Q92: Explanation

Correct Answer: C

- Visibility enables rapid response.
- SBOMs list components.
- Automation scales.

Key Takeaway

You cannot patch what you cannot find.

Q93: TPM and Secure Boot

Question

Which technology helps ensure that a device starts with trusted firmware and software?

(A) Screen lock policies with short timeouts

(B) Secure boot with a trusted platform module

(C) Full-disk encryption with a pre-boot password

(D) Frequent antivirus signature updates on every device

Q93: Explanation

Correct Answer: B

- Chain of trust validates startup.
- TPM stores keys and measurements.
- Helps detect tampering.

Key Takeaway

Secure boot protects the startup chain.

Q94: Immutable Infrastructure

Question

What is a security advantage of immutable infrastructure?

(A) Systems are patched manually and individually to preserve configuration

(B) Systems are never updated once they have been deployed

(C) Replace with known-good images, not in-place changes

(D) Systems run without images, so each build is unique and tailored

Q94: Explanation

Correct Answer: C

- Consistency reduces drift.
- Compromised instances can be replaced.
- Changes go through pipelines.

Key Takeaway

Replace, do not repair.

Q95: Time Source Attack

Question

Attackers tamper with a network time source to disrupt authentication and logs. Which control helps?

(A) Use a single unauthenticated time source for simplicity

(B) Disable time synchronization to avoid the attack path

(C) Accept time differences, since logs remain readable

(D) Use authenticated, redundant time sources

Q95: Explanation

Correct Answer: D

- Kerberos and logs rely on time.
- Redundancy reduces risk.
- Monitoring finds drift.

Key Takeaway

Time is a security dependency.

Q96: Noisy Neighbor

Question

In a multi-tenant cloud, another customer's heavy workload degrades your performance. Which risk is this?

(A) Resource contention; mitigate with reserved capacity

(B) A privacy breach caused by another customer reading your data

(C) A software defect in your own application code

(D) A phishing attack that targets your cloud administrators

Q96: Explanation

Correct Answer: A

- Shared resources can affect performance.
- Contracts and reservations help.
- Monitoring detects degradation.

Key Takeaway

Shared infrastructure can share performance risk.

Q97: Service Accounts

Question

Hundreds of service accounts have never-expiring passwords and broad access. What is the **BEST** approach?

(A) Inventory them, assign owners, rotate credentials, limit privileges

(B) Leave them unchanged, because changing them could break applications

(C) Share their credentials among teams to simplify troubleshooting

(D) Delete all service accounts and rebuild access from scratch

Q97: Explanation

Correct Answer: A

- Service accounts are often overlooked.
- Ownership and rotation reduce risk.
- Least privilege limits impact.

Key Takeaway

Non-human accounts need governance too.

Q98: DMARC Rollout

Question

The organization wants to enforce DMARC but fears blocking legitimate email. What is the **BEST** rollout?

(A) Move straight to reject, since spoofed mail must be stopped now

(B) Start in monitor mode, fix senders, then quarantine and reject

(C) Never enforce, because legitimate email might be affected

(D) Disable SPF and DKIM to remove the risk of false positives

Q98: Explanation

Correct Answer: B

- Reports reveal legitimate senders.
- Gradual enforcement avoids disruption.
- Final enforcement stops spoofing.

Key Takeaway

Monitor first, then enforce.

Q99: Cloud Storage Public Access

Question

A scan finds a storage container publicly accessible, holding customer data. What should be done **FIRST**?

(A) Wait until the next scheduled review to change the setting

(B) Delete the access logs so the exposure is not visible

(C) Take no action, since the container may not have been found

(D) Restrict access now, then assess the exposure

Q99: Explanation

Correct Answer: D

- Containment limits exposure.
- Logs help determine access.
- Incident and legal processes may apply.

Key Takeaway

Close the exposure, then investigate.

Q100: Break-Glass Accounts

Question

Why maintain emergency break-glass accounts?

(A) To give every administrator a convenient everyday login

(B) To avoid logging of sensitive administrative activity

(C) To bypass approval processes permanently for senior staff

(D) Monitored emergency access when normal login fails

Q100: Explanation

Correct Answer: D

- Emergencies require fallback.
- Strong controls prevent misuse.
- Use must be reviewed afterwards.

Key Takeaway

Break-glass access is rare, protected, and reviewed.

Exam Mindset Summary

Remember These Core Principles

- **Business First:** Risk is defined by its effect on business objectives.
- **Owners Decide:** Practitioners inform; owners accept, mitigate, transfer, or avoid.
- **Three Lines:** The first line owns risk, the second oversees, and the third gives independent assurance.
- **Ethics Matter:** Honesty, independence, and confidentiality underpin credible risk advice.
- **Evidence Over Opinion:** Use data, scenarios, and calibrated ratings.
- **Proportionality:** Controls should fit the risk and its cost.
- **Accountability Cannot be Outsourced:** Vendors and cloud providers share duties, but accountability remains with the organization.

Good Luck on Your CRISC Exam!

Real exam questions test your ability to apply these concepts in practical, real-world scenarios.